Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-22 09:00 WIB

Top 5 Highlights

• OpenAI’s models are deliberately breaking their misalignment monitoring systems

• PHP blames supply chain security biz Chainguard for putting huge chunks of the web at risk

• Amazon Threat Intelligence identifies PHP2Shell exploitation prior to public disclosure in MadPot

• Chrome puts insecure sites behind a permission prompt

• Google Chrome adds Gemini-powered scam detection, warns users of ClickFix attacks

Threat Intelligence (10)

01. Chrome puts insecure sites behind a permission prompt

Google has rolled out a change to Chrome that asks users for permission before making an insecure HTTP connection. The protection is now enabled by default for all users, following its introduction earlier this year for users of Safe Browsing’s Enhanced Protection mode. The vast majority of connections made by Chrome use HTTPS, according to Google. However,...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.helpnetsecurity.com/2026/10/22/google-chrome-https-protection/

02. Japan's Onamae Desktop Cloud hacked, up to 27,000 servers affected

Hackers compromised the infrastructure of Onamae Desktop Cloud, a popular provider of VPS services in Japan, and installed malware on up to 26,739 customers' servers. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/japans-onamae-desktop-cloud-hacked-up-to-27-000-servers-affected/

03. Lazarus hackers use post-quantum cryptography for malware delivery

North Korean hackers are using a post-quantum cryptographic mechanism to secure malicious payload delivery in new operations that combine old and new malware. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/lazarus-hackers-use-post-quantum-cryptography-for-malware-delivery/

04. AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise

Storm-0940 used ARTEX agentic AI to accelerate a ConnectWise supply chain compromise, enabling application credential abuse across Microsoft 365 environments. The post AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise appeared first on Microsoft Security Blog .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/

05. LiteLLM supply chain attack hoovers up passwords and secrets

Plus a RAT for good measure - get threat hunting now

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.theregister.com/security/2026/10/21/litellm-supply-chain-attack-hoovers-up-passwords-and-secrets/5304548

06. LiteLLM Compromised in Supply Chain Attack Delivering Credential Stealer and Backdoor

The popular LiteLLM Python package has been compromised as part of a software supply chain attack that delivered a credential stealer and a backdoor, according to reports from SafeDep, Socket, StepSecurity, and Upwind. The compromise affects LiteLLM 1.107.0, distributed through PyPI wheels and Docker images. The Python package has since been quarantined on…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://thehackernews.com/2026/10/litellm-compromised-in-supply-chain.html

07. OVHcloud GitHub Compromise Tied to GlassWorm Threat Actors

A developer's GitHub account that was compromised several months earlier was used to push malicious code to unsuspecting users.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.darkreading.com/cyberattacks-data-breaches/ovhcloud-github-compromise-glassworm-threat-actors

08. New PhaaS Platform Uses AI to Craft Phishing Lures and Mask Malicious Activity

Researchers have uncovered Athena StealthRoute, a phishing-as-a-service platform featuring an AI Studio that generates phishing lures and decoy content designed to conceal attacks

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.infosecurity-magazine.com/news/new-phaas-uses-ai-phishing-lures/

09. ClickFix has never been bigger, and AI tools are its most convincing lure yet

ClickFix attacks are surging as cybercriminals use fake AI installers, malicious search results, and trusted chatbot platforms to trick users into executing malware. Push Security examines how these attacks evade traditional defenses and why AI tools have become increasingly effective lures. […]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/clickfix-has-never-been-bigger-and-ai-tools-are-its-most-convincing-lure-yet/

10. Decades-Old Windows Utility Powers Modern ClickFix Attack

The attack uses malicious Google search results related to Amazon and leverages the "finger" utility to launch a CAPTCHA that installs malware, including the Lumma stealer.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.darkreading.com/cyberattacks-data-breaches/decades-old-windows-utility-modern-clickfix-attack

Latest Vulnerabilities (10)

01. OpenAI’s models are deliberately breaking their misalignment monitoring systems

AI agents are getting more inventive in finding ways to circumvent safeguards to prevent bad behavior, OpenAI has revealed. On Tuesday, it reported two incidents, both involving the agent disabling or interfering with its alignment monitoring, and in one case directly lying about having done so. “In two internal coding tasks, agents weakened misalignment mo…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4238782/openais-models-are-deliberately-breaking-their-misalignment-monitoring-systems.html

02. PHP blames supply chain security biz Chainguard for putting huge chunks of the web at risk

'Coordinated vulnerability disclosure, unless there's evidence of active exploits in the wild,' Chainguard CEO tells The Reg

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/security/2026/10/22/php-blames-supply-chain-security-biz-chainguard-for-putting-huge-chunks-of-the-web-at-risk/5304611

03. Amazon Threat Intelligence identifies PHP2Shell exploitation prior to public disclosure in MadPot

Amazon Threat Intelligence identified a PHP2Shell exploitation attempt dating to Oct. 17, 2026, in MadPot telemetry, four days before public disclosure of CVE-2026-109618 and CVE-2026-109619. The exploit attempt originated from an IP address associated with a commercial anonymization network. While the vulnerability was under embargo, the targeting of a hon...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://aws.amazon.com/blogs/security/amazon-threat-intelligence-identifies-php2shell-exploitation-prior-to-public-disclosure-in-madpot/

04. Hijacked Tor exit relays used to intercept SSH connections

Attackers compromised more than 300 Tor exit relays in early October to redirect SSH traffic and steal login credentials, according to a recent report by The Hacker News.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/hijacked-tor-exit-relays-used-to-intercept-ssh-connections

05. Two critical PHP flaws put the web on alert as emergency patches arrive

Organizations are scrambling to protect themselves following the disclosure of two critical vulnerabilities in commonly used code that powers much of the internet. The flaws discovered in the PHP scripting language could allow attackers to perform unauthenticated remote code execution (RCE). On Wednesday morning, the PHP Foundation released patches for affe...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4238692/two-critical-php-flaws-put-the-web-on-alert-as-emergency-patches-arrive.html

06. Critical PHP Vulnerability (CVE-2026-109618, CVE-2026-109619) [infocon yellow], (Wed, Oct 21st)

PHP.net announced that it will release a critical update today. We decided to change the infoCon to YELLOW due to the widespread use of PHP, the expected severity of the flaw (CVSS 9.4), and the availability of early PoC exploits before the patch became available.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://isc.sans.edu/diary/rss/33440

07. Microsoft: Treat AI agents as insider threats

EVP of Microsoft Security Hayete Gallot writes in a blog post that AI agents operating independently within companies could be a serious security threat. According to Microsoft, today’s most advanced AI models cannot be fully trusted. Not because they are malicious, but because they are trained to achieve goals and can take unexpected shortcuts to achieve t…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4238693/microsoft-treat-ai-agents-as-insider-threats.html

08. Stopping PHP2SHELL: How SentinelOne Protects Customers From This Attack Technique

Stop PHP2Shell with SentinelOne. Learn how Singularity Agent stops web worker post-exploitation, kills process trees, and hunts threats.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.sentinelone.com/blog/stopping-php2shell-how-sentinelone-protects-customers-from-this-attack-technique/

09. 'PHP2Shell' Bugs Signal Red Alert for Security Industry

Security teams are scrambling to remediate two critical PHP vulnerabilities following leaked details and reports of exploitation attempts.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/application-security/php2shell-bugs-red-alert-security-industry

10. Critical GitLab Flaw (CVSS 10.0) Could Allow Unauthenticated RCE Across 12 Years of Releases

GitLab released fixes on October 21 for a flaw that lets an attacker run code on a self-managed server without logging in, and it affects every version of the software going back to 7.0, released in 2014. The fix matters even for administrators who patched nine days earlier: the October 12 update covered only versions 19.2 and later, and the new fixed versi…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/critical-gitlab-flaw-cvss-100-could.html

Data Breach & Cybercrime (10)

01. Google Chrome adds Gemini-powered scam detection, warns users of ClickFix attacks

Chrome is getting new scam protections that use Gemini to detect deceptive websites and warn users when they copy suspicious commands from ClickFix attacks. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/google/google-chrome-adds-gemini-powered-scam-detection-warns-users-of-clickfix-attacks/

02. State Bank of India investigates suspected dark web data leak

State Bank of India is investigating a potential data breach involving thousands of customer records that appeared on a dark web forum, according to a recent report by Tech Radar.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/state-bank-of-india-investigates-suspected-dark-web-data-leak

03. Zeabur to shut down following major security breach

Zeabur is shutting down its development platform after a significant security breach resulted in the theft of millions of environment variable records and account information,

as first reported by Bleeping Computer.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/zeabur-to-shut-down-following-major-security-breach

04. California student data breach impacts millions

Coverage from Tech Radar indicates that a significant data breach has compromised the sensitive personal information of millions of current and former California public school students.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/california-student-data-breach-impacts-millions

05. TeamUpdraft security breach exposes WordPress site connection keys

According to Bleeping Computer, a threat actor breached the infrastructure of TeamUpdraft, a developer of popular WordPress backup and security plugins, potentially compromising connection keys used to manage remote websites.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/teamupdraft-security-breach-exposes-wordpress-site-connection-keys

06. US citizen pleads guilty to defrauding military members in identity theft scheme

Cyberscoop reports that a 45-year-old U.S. citizen has pleaded guilty to orchestrating a massive identity theft and fraud operation that targeted thousands of military service members and veterans.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/u-s-citizen-pleads-guilty-to-defrauding-military-members-in-identity-theft-scheme

07. TiDB Breach Exposes Flawed Cloud Security Assumptions

Cloud providers may be storing sensitive customer data, without either party knowing it. But when a provider is breached, the data comes home to roost.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/cloud-security/tidb-breach-flawed-cloud-security

08. Google Hardens Chrome Against ClickFix Attacks, Insecure HTTP Connections

Protections have been added against scams and social engineering, including new site warnings and server-side Gemini analysis. The post Google Hardens Chrome Against ClickFix Attacks, Insecure HTTP Connections appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.securityweek.com/google-hardens-chrome-against-clickfix-attacks-insecure-http-connections/

09. “Next Exploit Opportunities”: How a Threat Actor Used AI to Help Plan and Execute Multiple Types of Cybercrime Activities

An investigation into a threat actor bypassing AI safety controls to coordinate credential theft, VoIP fraud planning, and database exfiltration. The post “Next Exploit Opportunities”: How a Threat Actor Used AI to Help Plan and Execute Multiple Types of Cybercrime Activities appeared first on Unit 42 .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://unit42.paloaltonetworks.com/ai-assisted-cybercrime-analysis/

10. WordPress sites compromised after TeamUpdraft credential exposure

Attackers are using stolen connection keys exposed in a TeamUpdraft security breach to install malicious plugins on affected WordPress sites and establish persistent access. Sites already compromised may remain at risk even after the exposed credentials are revoked. The attacks followed unauthorized access to TeamUpdraft’s website. The company, which develo…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.csoonline.com/article/4238422/wordpress-sites-compromised-after-teamupdraft-credential-exposure.html